AI 결과를 어떻게 검증했나

보안 · 품질

발표자 3 · 7분

AI로 쇼핑몰 만들기 — 잘 묻고, 반드시 검증한다

AI는 그럴듯하게 틀립니다

코드는 돌아가고, 화면도 뜨고, 테스트도 통과한다. 그런데 틀렸다

검증을 세 층으로 깔았습니다

- ① **타입체크** — 컴파일 단계
- ② **자동 테스트 960개** — 계산 로직 · 화면 흐름
- ③ **보안 프로브 52건** — 실제 서버에 공격 요청을 던진다

> 이 중 ③번이 진짜를 잡았다

① 적립금을 세 배로 쓸 수 있었습니다

장바구니 3개에 10,000원 적립금을 동시에 사용

```
카트1: 200 OK  →  10,000원 할인
카트2: 200 OK  →  10,000원 할인
카트3: 200 OK  →  10,000원 할인

보유 10,000원인데  30,000원어치 할인
잔액: -20,000원
```

원인 — 락을 잘못된 단위로 잡았다

- 락 키가 **“장바구니별”**이었다
- 그런데 적립금 잔액은 **“고객별” 자산**
- 장바구니를 여러 개 만들면 서로 다른 락 → 의미 없음

> 주석에는 “동시 차감 방지”라고 적혀 있었다. 코드만 읽으면 안전해 보인다

② 환불이 세 번 나갔습니다

같은 요청번호로 1,000원 환불을 동시에 3번

```
3건 모두 성공
DB 환불 기록: 3건 (각 1,000원)

→ 1,000원 요청했는데  3,000원이 실제로 나감
```

> 순차로 보내면 정상적으로 막힌다. 동시에 보낼 때만 뚫린다 — 그래서 발견이 안 됐다

셋 다 원인이 같았습니다

```
검사  →  (락 없음)  →  집행
              ↑
        여기로 다른 요청이 끼어든다
```

> 고친 뒤 같은 공격을 다시 던져 확인 — 동시 5건 → 성공 1건, 잔액 정확히 0

저희 점검도 틀렸습니다

"완료"라고 적어둔 것이 틀린 경우

- **주석에는 "이중차감 방지"라고 적혀 있었습니다**
  일주일 전 점검에서 통과 처리한 항목이었다. 락을 걸긴 걸었는데 단위가 틀렸다
- **환불엔 고쳤는데 취소엔 반영을 안 했습니다**
  같은 원인, 다른 파일. 한 곳만 고치고 끝냈다
- **"화면이 안 바뀌면 고장"이라는 판정 기준이 오탐을 냈습니다**
  멀쩡한 기능 4개를 고장으로 표시했다

> 그래서 판정 기준을 **항목별로** 다시 잡았습니다 — URL · 쿠키 · 네트워크 요청 · 특정 요소

③ 소셜 로그인 — 모두가 같은 계정

브라우저 두 개로 각각 로그인

```
방문자 A  →  kakao-demo@shop.local
방문자 B  →  kakao-demo@shop.local     ← 같은 계정!
```

> 이대로 열었으면 고객 B가 고객 A의 주문내역·배송지·연락처를 그대로 봤을 것

검증을 자산으로 만들었습니다

찾은 걸 문서로만 남기지 않았다

- `presale-security-probe.mjs` — 27건 · 권한 · 인젝션 · 헤더
- `audit2-probe.mjs` — 19건 · 토큰위조 · 권한상승 · 입력경계
- `audit3-concurrency-probe.mjs` — 6건 · **동시 이중집행**

> 명령 한 줄이면 지금도 확인된다. 다시 생기면 바로 잡힌다

★ 숫자로 본 결과

항목	고치기 전	고친 뒤
적립금 동시 사용	10,000P로 30,000원 할인	동시 10건 → 성공 5건, 잔액 0
환불 동시 요청	3건 집행 (3,000원)	1건 집행 · 4건 거부
백엔드 린트	설정 자체가 없었음	218건 검출 → 0 error
취약점 (high)	스토어프론트 9 · 어드민 7	0 · 0
히어로 이미지	928KB PNG	11KB AVIF
관리자 죽은 버튼	17개	1개 연결 · 16개 비활성+사유

> 백엔드 high 4건은 **일부러 안 고쳤습니다** — 도달 불가를 실측으로 확인하고 이유를 문서에 남겼습니다.
> "전부 0" 보다 **왜 남겼는지 설명되는 것**이 중요합니다

검증하지 않았으면
돈이 새는 걸 몰랐을 겁니다

코드만 읽으면 안전해 보였고, 주석에도 "방지함"이라고 적혀 있었다

잘 묻고,
반드시 검증한다

저희가 배운 건 이거였습니다